

at_S25_A3_SL6_backend

Atividade Prática

Nome: _____ Turma: _____

Título da atividade: Rastreando ameaças: auditoria e logs para APIs seguras

1. Ferramentas de auditoria

1.1 Conceito

Ferramentas de auditoria ajudam a monitorar e registrar todas as atividades de uma API, identificando comportamentos anômalos e possíveis violações de segurança.

1.2 Boas práticas

- 1.2.1 Selecionar ferramentas que ofereçam recursos de centralização e análise de logs (ex.: ELK Stack, Splunk);
- 1.2.2 Configurar alertas para eventos críticos;
- 1.2.3 Realizar auditorias periódicas para detectar vulnerabilidades e comportamentos suspeitos.

1.3 Exemplo prático

Uma empresa pode utilizar o ELK Stack para consolidar logs de múltiplas APIs, permitindo que a equipe de segurança identifique rapidamente padrões de acesso anormais.

2. Configuração de Logs

2.1 Conceito

A configuração de logs envolve determinar quais eventos serão registrados, como serão armazenados e por quanto tempo os dados serão retidos para análise.

2.2 Boas práticas

- 2.2.1 Registrar eventos críticos, como tentativas de acesso, erros e operações sensíveis;
- 2.2.2 Garantir a integridade e a segurança dos arquivos de log;
- 2.2.3 Configurar políticas de retenção e rotação de logs para evitar sobrecarga de armazenamento.

2.3 Exemplo prático

Configurar um servidor para registrar acessos e erros de uma API, mantendo os logs por um período definido e utilizando criptografia para proteger os dados sensíveis armazenados.

3. Análise de dados

3.1 Conceito

A análise de dados de logs permite identificar padrões, detectar incidentes e tomar ações corretivas.

3.2 Boas práticas

- 3.2.1 Utilizar ferramentas de visualização e análise para filtrar e correlacionar eventos;
- 3.2.2 Estabelecer indicadores de desempenho e segurança;
- 3.2.3 Implementar revisões periódicas para ajustar as políticas de log e auditoria.

3.3 Exemplo prático

Após a análise dos logs, a equipe pode identificar uma série de tentativas de acesso repetidas de um mesmo IP, configurando um alerta e bloqueando o endereço suspeito.

Roteiro da atividade

1. Estudo teórico

Revisem os conceitos e boas práticas relacionados a ferramentas de auditoria, configuração de logs e análise de dados de segurança.

2. Caso prático

Imagine que vocês são responsáveis pela auditoria de segurança de uma API crítica. Elaborem um plano que inclua:

- 2.1 A seleção de ferramentas de auditoria adequadas;

- 2.2 A definição de quais eventos serão logados e como esses logs serão configurados;
- 2.3 Um procedimento para a análise periódica dos dados e identificação de incidentes.

3. Execução

Redijam um documento detalhado descrevendo o plano de auditoria e logs para a API, justificando cada escolha com base nas boas práticas apresentadas e exemplificando como as análises serão realizadas.

Perguntas da atividade:

Imagine que vocês receberam a seguinte mensagem no Slack:

"Equipe, identificamos algumas anomalias nos logs da nossa API e precisamos revisar nosso processo de auditoria. Como vocês recomendariam ajustar nossa configuração e análise de logs para detectar e responder a incidentes de segurança?"

Situação fictícia produzida pela SEDUC-SP.

- 1. Quais ferramentas de auditoria vocês recomendariam para centralizar e analisar os logs da nossa API, e por quê?
 - 2. Como vocês configurariam os logs para garantir que os eventos críticos sejam devidamente registrados e protegidos?
 - 3. Quais métodos de análise de dados vocês utilizariam para identificar incidentes de segurança a partir dos logs?
 - 4. Como vocês sugeririam melhorar a comunicação entre as equipes de segurança e TI para garantir uma resposta rápida a incidentes detectados pelos logs?
-
-


